

本表以個資生命週期各階段為主軸，呈現完整法條義務、施行細則對應條文，及 Global CBPR System Program Requirements 對照。「GCBPR 計畫要求」欄標示所屬隱私原則（粗體藍字）及問題編號與中文問題全文，取自中英文對照版 Enforcement Map（Annex B）。個人資料事故相關義務另見 05 個資事故對照表。「產業別辦法對應」欄及「差異標記」欄請搭配 01 AI Prompt 及 02 法規盤點對照表，依貴機構目的事業主管機關辦法填入（差異標記：○同基底／＋加嚴／△豁免／★新增義務／—不適用）。施行細則欄位中提及「本法」均指個資法。

This table follows the seven stages of the personal data lifecycle (Collection → Processing → Use → Storage → Domestic Transfer → Cross-border Transfer → Disposal) and maps each obligation to the Global CBPR Program Requirements. Personal-data-breach obligations are covered separately in Document 05. The "Industry-specific Rule Mapping" and "Variance Marker" columns are completed together with 01 AI Prompt and Document 02, based on the entity's sector-specific security-maintenance regulation (markers: ○ baseline / ＋ stricter / △ exempt / ★ additional obligation / — not applicable).

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
壹、蒐集階段						
◆ 個資法第 5 條（比例原則）	蒐集個人資料，應尊重當事人之權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。	—	蒐集目的識別及限制文件	[Collection Limitation] Q6: Do you limit your personal information collection (whether directly or through the use of third parties acting on your behalf) to information that is relevant to fulfil the purpose(s) for which it is collected or other compatible or related purposes?		
◆ 個資法第 7 條第 1 項（同意之方式）	第十五條第二款及第十九條第五款所稱經當事人同意，指當事人經蒐集者明確告知本法所定應告知事項後，所為允許之意思表示。	—	同意取得及撤回機制文件	[Choice] Q14: Subject to the Qualifications described below, do you provide a mechanism for individuals to exercise choice in relation to the collection of their personal information? Q17: When choices are provided to the individual offering the ability to limit the collection (Q14), use (Q15) and/or disclosure (Q16) of their personal information, are they displayed or provided in a clear and conspicuous manner? Q18: When choices are provided to the individual offering the ability to limit the collection (Q14), use (Q15) and/or disclosure (Q16) of their personal information, are they clearly worded and easily understandable? Q19: When choices are provided to the individual offering the ability to limit the collection (Q14), use (Q15) and/or disclosure (Q16) of their personal information, are these choices easily accessible and affordable?		
◆ 個資法第 8 條第 1 項（告知義務）	非公務機關向當事人蒐集個人資料時，應明確告知當事人：一、非公務機關名稱。二、蒐集之目的。三、個人資料之類別。四、個人資料利用之期間、地區、對象及方式。五、當事人依第三條規定得行使之權利及方式。六、當事人得自由選擇提供個人資料時，不提供將對其權益之影響。	◆ 施行細則第 16 條： 依本法第八條、第九條及第五十四條所定告知之方式，得以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。	隱私聲明／告知事項文件	[Notice] Q1: Do you provide clear and easily accessible statements about your practices and policies that govern the personal information described above (a privacy statement)? Q1a: 1a) Does this privacy statement describe how personal information is collected? Q1b: 1b) Does this privacy statement describe the purpose(s) for which personal information is collected? Q1c: 1c) Does this privacy statement inform individuals whether their personal information is made available to third parties and for what purpose? Q1d: 1d) Does this privacy statement disclose the name of the Applicant Organization's company and location, including contact information regarding		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
				practices and handling of personal information upon collection? Q1e: 1e) Does this privacy statement provide information regarding the use and disclosure of an individual's personal information? Q1f: 1f) Does this privacy statement provide information regarding whether and how an individual can access and correct their personal information? Q2: Subject to the Qualifications listed below, at the time of collection of personal information (whether directly or through the use of third parties acting on your behalf), do you provide notice that such information is being collected? Q3: Subject to the Qualifications listed below, at the time of collection of personal information (whether directly or through the use of third parties acting on your behalf), do you indicate the purpose(s) for which personal information is being collected? Q4: Subject to the Qualifications listed below, at the time of collection of personal information, do you notify individuals that their personal information may be shared with third parties?		
◆ 個資法第19條第1項（非公務機關蒐集特定目的）	非公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一：一、法律明文規定。二、與當事人有契約或類似契約之關係，且已採取適當之安全措施。三、當事人自行公開或其他已合法公開之個人資料。四、學術研究機構基於公共利益為統計或學術研究而有必要。五、經當事人同意。六、為增進公共利益所必要。七、個人資料取自一般可得之來源（但書）。八、對當事人權益無侵害。	◆ 施行細則第12條第1項：指公務機關或非公務機關為防止個人資料被竊取、竄改、毀損、滅失或洩漏，採取技術上及組織上之措施。	蒐集合法依據文件	[Collection Limitation] Q7: Do you collect personal information (whether directly or through the use of third parties acting on your behalf) by lawful and fair means, consistent with the requirements of the jurisdiction that governs the collection of such personal information?		
◆ 個資法第6條第1項（特種資料之蒐集限制）	有關病歷、醫療、基因、性生活、健康檢查及犯罪前科之個人資料，不得蒐集、處理或利用。但有下列情形之一者，不在此限：一、法律明文規定。二、公務機關執行法定職務或非公務機關履行法定義務。三、當事人自行公開或其他已合法公開。四、公務機關或學術研究機構基於醫療、衛生或犯罪預防之目的，為統計或學術研究而有必要，且經一定程序。五、為協助公務機關執行法定職務或非公務機關履行法定義務。六、經當事人書面同意。	◆ 施行細則第14條：本法第六條第一項但書第六款……所定當事人書面同意之方式，依電子簽章法之規定，得以電子文件為之。	特種資料蒐集審查紀錄	[Collection Limitation] Q5: How do you obtain personal information: 5a) Directly from the individual? 5b) From third parties collecting on your behalf? 5c) Other. Q6: Do you limit your personal information collection (whether directly or through the use of third parties acting on your behalf) to information that is relevant to fulfil the purpose(s) for which it is collected or other compatible or related purposes? Q7: Do you collect personal information (whether directly or through the use of third parties acting on your behalf) by lawful and fair means, consistent with the requirements of the jurisdiction that governs the collection of such personal information?		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 1 款： 一、配置管理之人員及相當資源。	資訊安全政策文件	[Security Safeguards] Q26: Have you implemented an information security policy?		
		◆ 施行細則第 12 條第 2 項第 2 款： 二、界定個人資料之範圍。	個人資料盤點清冊	[Collection Limitation] Q5: How do you obtain personal information: 5a) Directly from the individual? 5b) From third parties collecting on your behalf? 5c) Other. Q6: Do you limit your personal information collection (whether directly or through the use of third parties acting on your behalf) to information that is relevant to fulfil the purpose(s) for which it is collected or other compatible or related purposes?		
貳、處理階段						
◆ 個資法第 5 條（比例原則）	蒐集個人資料，應尊重當事人之權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。	—	個人資料處理活動紀錄	[Uses of Personal Information] Q8: Do you limit the use of the personal information you collect (whether directly or through the use of third parties acting on your behalf), as identified in your privacy statement and/or in the notice provided at the time of collection, to those purposes for which the information was collected or for other compatible or related purposes?		
◆ 個資法第 20 條第 1 項（處理之合法基礎）	非公務機關對個人資料之利用，除第六條第一項所規定資料外，應於蒐集之特定目的必要範圍內為之。但有下列情形之一者，得為特定目的外之利用：一、法律明文規定。二、為增進公共利益所必要。三、為免除當事人之生命、身體、自由或財產上之危險。四、為防止他人權益之重大危害。五、公務機關或學術研究機構基於公共利益為統計或學術研究之必要，且資料經過提供者處理後或蒐集者依其揭露方式無從識別特定當事人。六、有利於當事人權益。七、經當事人同意。	—	蒐集合法依據文件 隱私聲明／告知事項文件	[Uses of Personal Information] Q8: Do you limit the use of the personal information you collect (whether directly or through the use of third parties acting on your behalf), as identified in your privacy statement and/or in the notice provided at the time of collection, to those purposes for which the information was collected or for other compatible or related purposes? Q9: If you answered NO to Q8, do you use the personal information you collect for unrelated purposes under one of the following circumstances? 9a) Based on express consent of the individual? 9b) Compelled by applicable laws?		
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 1 項： 指公務機關或非公務機關為防止個人資料被竊取、竄改、毀損、滅失或洩漏，採取技術上及組織上之措施。 ◆ 施行細則第 12 條第 2 項第 5 款： 五、個人資料蒐集、處理及利用之內部管理程序。	安全防護措施實施紀錄	[Security Safeguards] Q26: Have you implemented an information security policy? Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q28: Describe how the safeguards identified in response to Q27 are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held.		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
◆ 個資法第4條（委託關係）	受公務機關或非公務機關委託蒐集、處理或利用個人資料者，於本法適用範圍內，視同委託機關。	◆ 施行細則第8條： 委託他人蒐集、處理或利用個人資料時，委託機關應對受託者為適當之監督。前項監督至少應包含： 一、預定蒐集、處理或利用個人資料之範圍、類別、特定目的及其期間。二、受託者就第十二條第二項採取之措施。三、有複委託者，其約定之受託者。四、受託者或其受僱人違反本法時，應向委託機關通知之事項及採行之補救措施……委託機關應定期確認受託者執行之狀況，並將確認結果記錄之。	委外處理者契約及監督紀錄	[Security Safeguards] Q35: Do you require personal information processors, agents, contractors, or other service providers to whom you transfer personal information to protect against loss, or unauthorized access, destruction, use, modification or disclosure or other misuses of the information by: 35a) Implementing an information security program that is proportionate to the sensitivity of the information and services provided? 35b) Notifying you promptly when they become aware of an occurrence of breach of the privacy or security of the personal information of the Applicant Organization's customers? 35c) Taking immediate steps to correct/address the security failure which caused the privacy or security breach?		
參、利用階段						
◆ 個資法第7條第1項（特定目的內利用告知）	第十五條第二款及第十九條第一項第五款所稱同意，指當事人經蒐集者告知本法所定應告知事項後，所為允許之意思表示。	—	個人資料處理活動紀錄	[Uses of Personal Information] Q10: Do you disclose personal information you collect (whether directly or through the use of third parties acting on your behalf) to other personal information controllers? Q11: Do you transfer personal information to personal information processors? Q12: If you answered YES to Q10 and/or Q11, is the disclosure and/or transfer undertaken to fulfill the original purpose of collection or another compatible or related purpose? Q13: If you answered NO to Q12, or if otherwise appropriate, does the disclosure and/or transfer take place under one of the following circumstances? 13a) Based on express consent of the individual? 13b) Necessary to provide a service or product requested by the individual? 13c) Compelled by applicable laws?		
◆ 個資法第20條第1項（特定目的內利用）	非公務機關對個人資料之利用，除第六條第一項所規定資料外，應於蒐集之特定目的必要範圍內為之。但有下列情形之一者，得為特定目的外之利用：一、法律明文規定。二、為增進公共利益所必要。三、為免除當事人之生命、身體、自由或財產上之危險。四、為防止他人權益之重大危害。五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。六、經當事人同意。七、有利於當事人權益。	—				

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
◆ 個資法第 7 條第 2 項（目的外利用告知）	第十六條第七款、第二十條第一項第六款所稱同意，指當事人經蒐集者明確告知特定目的外之其他利用目的、範圍及同意與否對其權益之影響後，單獨所為之意思表示。	◆ 施行細則第 15 條： 本法第七條第二項所定單獨所為之意思表示，如係與其他意思表示於同一書面為之者，蒐集者應於適當位置使當事人得以知悉其內容並確認同意。	目的外利用告知文件	[Choice] Q15: Subject to the Qualifications described below, do you provide a mechanism for individuals to exercise choice in relation to the use of their personal information? Q16: Subject to the Qualifications described below, do you provide a mechanism for individuals to exercise choice in relation to the disclosure of their personal information? Q20: What mechanisms are in place so that choices, where appropriate, can be honored in an effective and expeditious manner?		
◆ 個資法第 3 條（當事人權利）	當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之：一、查詢或請求閱覽。二、請求製給複製本。三、請求補充或更正。四、請求停止蒐集、處理或利用。五、請求刪除。	◆ 施行細則第 19 條： 當事人依本法第十一條第一項規定向公務機關或非公務機關請求更正或補充其個人資料時，應為適當之釋明。	個人存取更正程序文件	[Access and Correction] Q36: Upon request, do you provide confirmation of whether or not you hold personal information about the requesting individual? Q37: Upon request, do you provide individuals access to the personal information that you hold about them? 37a) Do you take steps to confirm the identity of the individual requesting access? 37b) Do you provide access within a reasonable time frame following an individual's request for access? 37c) Is information communicated in a reasonable manner that is generally understandable? 37d) Is information provided in a way that is compatible with the regular form of interaction with the individual? 37e) Do you charge a fee for providing access? Q38: Do you permit individuals to challenge the accuracy of their information, and to have it rectified, completed, amended and/or deleted? 38a) Are your access and correction mechanisms presented in a clear and conspicuous manner? 38b) If an individual demonstrates that personal information about them is incomplete or incorrect, do you make the requested correction, addition, or where appropriate, deletion? 38c) Do you make such corrections or deletions within a reasonable time frame following an individual's request? 38d) Do you provide a copy of the corrected personal information, or confirmation that it has been corrected or deleted? 38e) If access or correction is refused, do you notify the individual with an explanation and contact information for further inquiries?		
肆、儲存階段						
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 1 款： 一、配置管理之人員及相當資源。	資訊安全政策文件	[Security Safeguards] Q26: Have you implemented an information security policy?		
		◆ 施行細則第 12 條第 2 項第 2 款： 二、界定個人資料之範圍。	個人資料資產清冊	[Collection Limitation] Q5: How do you obtain personal information: 5a) Directly from the individual? 5b) From third parties collecting on your behalf? 5c) Other.		
		◆ 施行細則第 12 條第 2 項第 3 款： 三、個人資料之風險評估及管理機制。	風險評估紀錄	[Security Safeguards] Q28: Describe how the safeguards identified in response to Q27 are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held. Q34: Do you use third-party certifications or other risk assessments?		
		◆ 施行細則第 12 條第 2 項第 4	資安事故偵測、預	[Security Safeguards]		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
		款： 四、事故之預防、通報及應變機制。	防及回應措施文件	Q32: Have you implemented measures to detect, prevent, and respond to attacks, intrusions, or other security failures? Q33: Do you have processes in place to test the effectiveness of the safeguards referred to in Q32?		
		◆ 施行細則第 12 條第 2 項第 5 款： 五、個人資料蒐集、處理及利用之內部管理程序。	個人資料處理活動紀錄	[Accountability] Q39: What measures do you take to ensure compliance with the Global CBPR Privacy Principles? (Internal guidelines or policies / Contracts / Compliance with applicable industry or sector laws and regulations / Compliance with self-regulatory Applicant Organization code and/or rules / Other)		
		◆ 施行細則第 12 條第 2 項第 6 款： 六、資料安全管理及人員管理。	實體、技術及行政安全防護措施文件	[Security Safeguards] Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q30: Have you implemented safeguards that are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held, through: 30a) Employee training and management or other safeguards? 30b) Information systems and management, including network and software design, as well as information processing, storage, transmission, and disposal? 30c) Detecting, preventing, and responding to attacks, intrusions, or other security failures? 30d) Physical security?		
		◆ 施行細則第 12 條第 2 項第 7 款： 七、認知宣導及教育訓練。	員工隱私教育訓練紀錄	[Security Safeguards] Q29: Describe how you make your employees aware of the importance of maintaining the security of personal information (e.g., through regular training and oversight).		
		◆ 施行細則第 12 條第 2 項第 8 款： 八、設備安全管理。	實體安全防護措施文件	[Security Safeguards] Q30: Have you implemented safeguards that are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held, through: 30a) Employee training and management or other safeguards? 30b) Information systems and management, including network and software design, as well as information processing, storage, transmission, and disposal? 30c) Detecting, preventing, and responding to attacks, intrusions, or other security failures? 30d) Physical security?		
		◆ 施行細則第 12 條第 2 項第 9 款： 九、資料安全稽核機制。	稽核計畫及稽核結果紀錄	[Security Safeguards] Q32: Have you implemented measures to detect, prevent, and respond to attacks, intrusions, or other security failures? Q33: Do you have processes in place to test the effectiveness of the safeguards referred to in Q32? Q34: Do you use third-party certifications or other risk assessments?		
◆ 個資法第 11 條第 3 項（正確性維護義務）	個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意者，不在此	◆ 施行細則第 19 條： 當事人依本法第十一條第一項規定向公務機關或非公務機關請求更正或補充其個人資料時，應為適當之	個人資料處理活動紀錄	[Integrity of Personal Information] Q21: Do you take steps to verify that the personal information held by you is up to date, accurate and complete, to the extent necessary for the purposes of use? Q22: Do you have a mechanism for correcting inaccurate, incomplete and		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
	限。	釋明。		outdated personal information to the extent necessary for purposes of use?		
◆ 個資法第 11 條第 4 項（保存期限限制）	個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。	◆ 施行細則第 20 條、第 21 條：特定目的消失之定義及因執行職務或業務所必須之情形。	資料保留及安全銷毀政策	[Security Safeguards] Q31: Have you implemented a policy for secure disposal of personal information?		
伍、傳輸（國內）階段						
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 1 項（適當安全維護措施定義）	資訊傳輸安全規則及協議文件	[Security Safeguards] Q35: Do you require personal information processors, agents, contractors, or other service providers to whom you transfer personal information to protect against loss, or unauthorized access, destruction, use, modification or disclosure or other misuses of the information by: 35a) Implementing an information security program that is proportionate to the sensitivity of the information and services provided? 35b) Notifying you promptly when they become aware of an occurrence of breach of the privacy or security of the personal information of the Applicant Organization's customers? 35c) Taking immediate steps to correct/address the security failure which caused the privacy or security breach?		
◆ 個資法第 4 條（委託關係—傳輸面向）	受公務機關或非公務機關委託蒐集、處理或利用個人資料者，於本法適用範圍內，視同委託機關。	◆ 施行細則第 8 條： 委託他人蒐集、處理或利用個人資料時，委託機關應對受託者為適當之監督……	委外處理者問責機制文件	[Accountability] Q46: Do you have mechanisms in place with personal information processors, agents, contractors, or other service providers pertaining to personal information they process on your behalf, to ensure that your obligations to the individual will be met? Q47: Do these agreements generally require that personal information processors, agents, contractors or other service providers: abide by your Global CBPR-compliant privacy policies stated in your privacy statement? implement substantially similar privacy practices? follow your instructions on handling personal information? restrict subcontracting without your consent? notify you in the event of a breach of your customers' personal information? Q48: Do you require your personal information processors, agents, contractors or other service providers to provide you with self-assessments to ensure compliance with your instructions and/or agreements/contracts? Q49: Do you carry out regular spot checking or monitoring of your personal information processors, agents, contractors or other service providers to ensure compliance with your instructions and/or agreements/contracts?		
陸、跨境傳輸階段						
◆ 個資法第 21 條（國際傳輸限制）	非公務機關為國際傳輸個人資料，而有下列情形之一者，中央目的事業主管機關得限制之：一、涉及國家重要利益。二、國際條約或協定有特別規定。三、接受國對於個人資料之保護未有完善之法規，致有	—	跨境傳輸評估及保護措施文件	[Accountability] Q50: Do you disclose personal information to other recipient persons or organizations in situations where due diligence and reasonable steps to ensure compliance with the Global CBPR System by the recipient are impractical or impossible?		

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements	產業別辦法對應	差異標記
	損害當事人權益之虞。四、以迂迴方式向第三國（地區）傳輸個人資料規避本法。					
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 1 項（適當安全維護措施定義）	資訊傳輸安全規則及協議文件	[Uses of Personal Information] Q10: Do you disclose personal information you collect (whether directly or through the use of third parties acting on your behalf) to other personal information controllers? Q12: If you answered YES to Q10 and/or Q11, is the disclosure and/or transfer undertaken to fulfill the original purpose of collection or another compatible or related purpose?		
柒、銷毀階段						
◆ 個資法第 11 條第 3、4 項（刪除義務）	個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。違反本法規定蒐集、處理或利用個人資料者，應主動或依當事人之請求，刪除、停止蒐集、處理或利用該個人資料。	◆ 施行細則第 20 條、第 21 條：特定目的消失之定義及因執行職務或業務所必須之情形。	資料保留及安全銷毀政策	[Security Safeguards] Q31: Have you implemented a policy for secure disposal of personal information?		
◆ 個資法第 12 條（事故通知當事人義務）	非公務機關違反本法規定，致個人資料被竊取、洩漏、竄改或其他侵害者，應查明後以適當方式通知當事人。	◆ 施行細則第 22 條： 本法第十二條所稱適當方式通知，指即時以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。但需費過鉅者，得斟酌技術之可行性及當事人隱私之保護，以網際網路、新聞媒體或其他適當公開方式為之。依本法第十二條規定通知當事人，其內容應包括個人資料被侵害之事實及已採取之因應措施。	資安事故偵測、預防及回應措施文件（含隱私侵害事故通知）	[Security Safeguards] Q32: Have you implemented measures to detect, prevent, and respond to attacks, intrusions, or other security failures? Q35: Do you require personal information processors, agents, contractors, or other service providers to whom you transfer personal information to protect against loss, or unauthorized access, destruction, use, modification or disclosure or other misuses of the information by: 35a) Implementing an information security program that is proportionate to the sensitivity of the information and services provided? 35b) Notifying you promptly when they become aware of an occurrence of breach of the privacy or security of the personal information of the Applicant Organization's customers? 35c) Taking immediate steps to correct/address the security failure which caused the privacy or security breach?		
◆ 個資法第 27 條第 1 項（安全維護義務—持續問責）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 11 款： 十一、個人資料安全維護之整體持續改善。	申訴受理及回應程序文件	[Accountability] Q41: Do you have procedures in place to receive, investigate and respond to privacy-related complaints? Q42: Do you have procedures in place to ensure individuals receive a timely response to their complaints? Q43: If YES to Q42, does this response include an explanation of remedial action relating to their complaint?		